

Amar Telidji University Laghouat

Department of Computer Science

Level: 4th Year Engineering

Course: Computer Systems Security

Lab 01: Building and Administering
a Secure System

Supervised by:

Mr. Mohamed Lahcen BENSAAD

Prepared by:

Smail MERSAD

Academic Year: 2025 / 2026

Part 1 — Secure System Fundamentals

Step 01: Configure SSH Key Authentication

```
smaill@FALCON-PC:~$ ssh-keygen -t rsa -b 4096 -C "student@securelab"
Generating public/private rsa key pair.
Enter file in which to save the key (/home/smaill/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/smaill/.ssh/id_rsa
Your public key has been saved in /home/smaill/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:uNYArfkGjKWfKc1GLy+vZ/C5dG0E2gk8nj4+ei0i0j0 student@securelab
The key's randomart image is:
+---[RSA 4096]-----+
|
|      o
|     o = .
|    = = B o
|   o * * S .
|  =.B + o
| .. 0oXoo o
|. EooB0o..
|.o ooX=+
+-----[SHA256]-----+
```

```
smaill@FALCON-PC:~$ ssh-copy-id eng@10.233.28.78
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/smaill/.ssh/id_rsa.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already
installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install
the new keys
eng@10.233.28.78's password:

Number of key(s) added: 1

Now try logging into the machine, with:  "ssh 'eng@10.233.28.78'"
and check to make sure that only the key(s) you wanted were added.
```

```
smail@FALCON-PC:~$ ssh eng@10.233.28.78
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-59-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Oct 28 13:01:36 2025 from 10.233.28.61
eng@ubuntu-server-base:~$
```

Step 02: Explore System Weaknesses

```
eng@ubuntu-server-base:~$ sudo nmap -sS localhost
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-28 20:16 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000033s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds
```

Open Ports:

- 22/tcp (SSH) — Secure Shell service enabled for remote administration.

Unnecessary or Risky Services:

- None detected. Only SSH is active, which is required for remote management.

If present, services like cups, avahi-daemon, or telnet should be disabled to reduce the attack surface.

Step 03: User and Group Management

Testing limited privilege access:

```
eng@ubuntu-server-base:~$ su - staff1
Password:
staff1@ubuntu-server-base:~$ sudo apt update
[sudo] password for staff1:
Sorry, user staff1 is not allowed to execute '/usr/bin/apt update' as root on ubuntu-server-base.
```

Description:

- Created users admin, staff1, and guest. Added staff1 to a shared group office. Configured sudo privileges to give admin full administrative rights and restrict staff1 to only ls and cat commands.

Observation:

- staff1 was able to execute allowed commands but was denied when attempting administrative tasks (sudo apt update).

Principle:

- This demonstrates the Principle of Least Privilege, ensuring each user only performs required operations, reducing the risk of accidental or malicious system changes.

Step 04: File Permissions and Access Control

```
eng@ubuntu-server-base:~$ ls -l /home/shared/confidential.txt
-rw-r----- 1 admin office 18 Oct 28 21:45 /home/shared/confidential.txt
```

```
eng@ubuntu-server-base:~$ su - guest
Password:
guest@ubuntu-server-base:~$ cat /home/shared/confidential.txt
cat: /home/shared/confidential.txt: Permission denied
```

```
eng@ubuntu-server-base:~$ sudo setfacl -m u:staff1:r /home/shared/confidential.txt
eng@ubuntu-server-base:~$ getfacl /home/shared/confidential.txt
getfacl: Removing leading '/' from absolute path names
# file: home/shared/confidential.txt
# owner: admin
# group: office
user::rw-
user:staff1:r--
group::r--
mask::r--
other::---
```

Description:

- Created a shared directory /home/shared with a confidential file. Assigned ownership to admin and group office, then restricted permissions using chmod 640. Verified that only authorized users (admin and members of office) could read the file. Used ACL to explicitly grant read permission to a specific user (staff1).

Observation:

- Before applying the ACL, staff1 was already able to view the file contents due to group membership. The ACL command did not change access behavior but confirmed that fine-grained permissions can explicitly grant or manage access on a per-user basis beyond standard Unix permissions.

Principle:

- Proper file ownership, permissions, and ACLs enforce confidentiality and integrity, ensuring that only authorized users can access sensitive information.

Step 05: Password and Authentication Policies

Verify user password aging

```
eng@ubuntu-server-base:~$ sudo chage -l guest
Last password change           : Oct 28, 2025
Password expires               : Jan 26, 2026
Password inactive              : never
Account expires                : never
Minimum number of days between password change : 1
Maximum number of days between password change : 90
Number of days of warning before password expires : 7
```

Password complexity enforcement

```
eng@ubuntu-server-base:~$ sudo passwd guest
New password:
BAD PASSWORD: The password contains less than 1 digits
New password:
```

Description:

- Configured password aging and complexity policies to strengthen authentication. Updated /etc/login.defs to enforce password expiration (90 days), minimum change interval (1 day), and 7-day warning. Modified /etc/pam.d/common-password to require strong passwords (minimum 10 characters with mixed case, digits, and symbols).

Observation:

- Existing users were updated with the chage command. Weak passwords (e.g., "guest123") were rejected, while strong passwords (e.g., "Guest@2025") were accepted.

Principle:

- Strong and regularly rotated passwords prevent credential compromise and maintain system integrity.

Step 6: Reflection

- SSH keys use asymmetric encryption and are nearly impossible to brute-force compared to passwords. A private key is stored securely on the client and never transmitted over the network, while password authentication sends credentials (even if encrypted) that can still be guessed or phished. SSH key authentication effectively eliminates weak password risks and defends against brute-force attacks.
- Standard Unix permissions (rwx for user, group, others) are limited to one owner and one group. ACLs (Access Control Lists) allow fine-grained control — you can assign specific permissions to multiple users or groups on the same file. This provides flexibility in multi-user environments without changing ownership or groups.

Part 2 — System Hardening and Auditing

Step 01: System Hardening

```
eng@ubuntu-server-base:~$ sudo systemctl disable cups
[sudo] password for eng:
Failed to disable unit: Unit file cups.service does not exist.
eng@ubuntu-server-base:~$ sudo systemctl disable avahi-daemon
Failed to disable unit: Unit file avahi-daemon.service does not exist.
eng@ubuntu-server-base:~$ _
```

Observation:

- Attempting to disable cups and avahi-daemon returned “Unit file does not exist,” indicating these unnecessary services are not installed. This confirms that the Ubuntu Server image is already optimized with a minimal service set. Enabled unattended security updates to ensure the system applies patches automatically. Locked the root account to prevent direct login and enforce controlled privilege escalation through sudo. Verified remaining active services.

Principle:

- System hardening reduces potential entry points and automates patch management, ensuring integrity and minimizing maintenance risk.

Step 02: Firewall Configuration

```
eng@ubuntu-server-base:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip
```

To	Action	From
--	-----	----
22/tcp (OpenSSH)	ALLOW IN	Anywhere
80/tcp	ALLOW IN	Anywhere
22/tcp (OpenSSH (v6))	ALLOW IN	Anywhere (v6)
80/tcp (v6)	ALLOW IN	Anywhere (v6)

```
eng@ubuntu-server-base:~$ sudo nmap -sS localhost
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-31 10:20 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000080s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
eng@ubuntu-server-base:~$
```

Description:

- Configured a restrictive firewall policy using UFW. Set defaults to deny all incoming traffic and allow outgoing traffic. Explicitly allowed only SSH (22/tcp). Enabled the firewall and verified active rules.

Observation:

- ufw status verbose shows the correct rules and confirms the firewall is active. Nmap scan results indicate only ports 22 are open, proving that all other ports are blocked.

Principle:

- A restrictive firewall enforces controlled access, limits exposure, and complements other hardening measures by ensuring only essential services are reachable.

Step 03: Auditing and Logging

```
eng@ubuntu-server-base:~$ sudo journalctl | grep "Failed password" > failed_logins.txt
^[[A^[[Aeng@ubuntu-server-base:~$ cat failed_logins.txts.txt
Oct 15 09:54:47 ubuntu-server-base sshd[897]: Failed password for eng from 10.233.28.217 port 52896 ssh2
Oct 22 09:31:08 ubuntu-server-base sshd[1138]: Failed password for eng from 10.233.28.217 port 52980 ssh2
Oct 22 09:48:27 ubuntu-server-base sshd[851]: Failed password for eng from 192.168.43.2 port 38710 ssh2
Oct 31 10:26:32 ubuntu-server-base sudo[1407]: eng : TTY=pts/0 ; PWD=/home/eng ; USER=root ; COMMAND=/usr/bin/grep 'Failed password' /var/log/auth.log
Oct 31 10:28:34 ubuntu-server-base sudo[1414]: eng : TTY=pts/0 ; PWD=/home/eng ; USER=root ; COMMAND=/usr/bin/grep 'Failed password' /var/log/auth.log
Oct 31 10:29:30 ubuntu-server-base sudo[1429]: eng : TTY=pts/0 ; PWD=/home/eng ; USER=root ; COMMAND=/usr/bin/grep 'Failed password' /var/log/auth.log
Oct 31 10:32:31 ubuntu-server-base sudo[1898]: eng : TTY=pts/0 ; PWD=/home/eng ; USER=root ; COMMAND=/usr/bin/grep 'Failed password' /var/log/auth.log
Oct 31 10:34:30 ubuntu-server-base sudo[1901]: eng : TTY=pts/0 ; PWD=/home/eng ; USER=root ; COMMAND=/usr/bin/grep 'Failed password' /var/log/auth.log
eng@ubuntu-server-base:~$
```

Observation:

- Initially, no **/var/log/auth.log** file was found because the system used **systemd-journald** instead of **rsyslog**.
- Authentication attempts were retrieved using **journalctl | grep "Failed password"**, which showed the same information.

Principle:

- Continuous auditing and log analysis enhance visibility and help identify suspicious behavior before it leads to compromise.

Step 04: Intrusion Prevention with Fail2Ban

```
eng@ubuntu-server-base:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|   |- Currently failed: 0
|   |- Total failed:     5
|   `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
    |- Currently banned: 1
    |- Total banned:     1
    `-- Banned IP list:  10.233.28.116
```

Description:

- Installed and activated Fail2Ban to automatically block repeated failed SSH login attempts. Verified that the sshd jail is active and monitoring SSH authentication failures.

Observation:

- Because SSH key-based authentication was enforced earlier (Step 1 Part 1), password-based logins were temporarily disabled. To simulate failed SSH attempts and

test Fail2Ban's functionality, PasswordAuthentication was re-enabled in /etc/ssh/sshd_config. After restarting the SSH service, several failed password attempts were made from the host machine, which successfully triggered Fail2Ban. The fail2ban-client status sshd output confirmed the offending IP was detected and banned.

Principle:

- Automated intrusion prevention complements system hardening by dynamically blocking repeated login failures. This maintains system availability and prevents brute-force attacks in real time.

Step 05: Security Audit using Lynis

```
Lynis security scan details:

Hardening index : 66 [#####          ]
Tests performed : 257
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit      [V]
- Vulnerability scan  [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

I got a **66** score.

Recommendations:

1. **Enable auditd to collect audit information [ACCT-9628]:** Adds a dedicated auditing service that records security-relevant events (file access, privilege use, etc.) for compliance and forensics.
2. **Consider hardening SSH configuration [SSH-7408]:** Multiple SSH parameters (like MaxAuthTries, AllowTcpForwarding, and X11Forwarding) can be tightened to reduce brute-force and lateral movement risk.
3. **Harden the system by installing a malware scanner [HRDN-7230]:** Tools like rkhunter or chkrootkit detect rootkits or malware persistence mechanisms in critical directories.

Reflection:

The most important lesson I learned from securing my system is that security isn't one command, it's discipline. Each layer, from limiting open ports and enforcing SSH key authentication to logging, auditing, and intrusion prevention, plays a clear role in reducing risk. Hardening isn't about running tools blindly but understanding how configurations work together to protect availability, integrity, and confidentiality. Tools like UFW, Fail2Ban, and Lynis proved that visibility and automation make defense sustainable. System security is ongoing awareness not a one-time setup, but a continuous process of tightening and verifying.